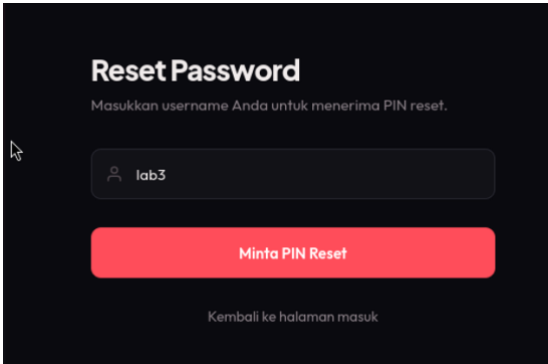


Incident report

Weak Password Reset — Brute-force PIN 3-digit	
Tingkat Keparahan	HIGH
CVSS Score 3.1	CVSS : 3.1 / AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Deskripsi	Fitur password reset mengandalkan PIN numerik dengan ruang kombinasi yang terbatas. Selain itu, endpoint tidak menerapkan kontrol yang memadai terhadap jumlah percobaan PIN. Kondisi tersebut memungkinkan attacker melakukan brute-force terhadap PIN dengan mencoba kombinasi secara otomatis.
URL Terdampak	http://194.233.89.48:5000/forgot-password
Dampak	Dampak utama vulnerability adalah Account Takeover (ATO). Attacker yang berhasil memperoleh PIN dapat melakukan password reset terhadap akun target dan mengambil alih akun tersebut. Apabila target merupakan akun administrator, dampaknya menjadi lebih serius karena attacker dapat memperoleh akses ke fungsi administratif. Dampak potensial meliputi: • Unauthorized account takeover. • Pengambilalihan akun administrator. • Akses terhadap data yang dapat diakses oleh akun target. • Modifikasi data dan konfigurasi yang memiliki hak akses target. • Penyalahgunaan privilege administrator. • Potensi kompromi lebih lanjut terhadap aplikasi.
Kategori	Website
Rekomendasi	Implementasikan Rate Limiting Batasi jumlah percobaan PIN pada endpoint password reset, baik berdasarkan akun target maupun sumber request. Contohnya, setelah sejumlah percobaan gagal, request berikutnya harus ditunda atau diblokir sementara. Gunakan PIN dengan Entropy yang Lebih Tinggi Gunakan OTP/PIN dengan ruang kombinasi yang lebih besar dan dihasilkan menggunakan cryptographically secure random generator.

	Batasi Jumlah Percobaan PIN harus memiliki batas maksimal percobaan. Setelah batas tersebut tercapai, PIN harus di-invalidasi dan proses reset perlu dimulai kembali. Expiration dan One-time Use PIN harus: • Memiliki masa berlaku yang singkat. • Hanya dapat digunakan satu kali. • Segera di-invalidasi setelah berhasil digunakan. Monitoring Implementasikan logging dan detection terhadap pola percobaan PIN yang abnormal, seperti ratusan request reset dalam waktu singkat.
Referensi	https://medium.com/@g.a.istrati/sql-injection-vulnerability-allowing-login-bypass-911e5b6ac656
Bukti Temuan	
Ditemukan kerentanan pada fitur password reset karena sistem menggunakan PIN/OTP dengan jumlah kombinasi yang sangat terbatas dan tidak menerapkan mekanisme rate limiting yang memadai. PIN reset terdiri dari 3 digit, sehingga hanya terdapat 1.000 kemungkinan kombinasi (000–999). Karena aplikasi tidak membatasi jumlah percobaan, attacker dapat mencoba seluruh kombinasi menggunakan automated request melalui Burp Suite Intruder hingga menemukan PIN yang valid. Kerentanan ini berpotensi menyebabkan account takeover, termasuk terhadap akun dengan privilege administrator.	
	

Turbo Intruder - 194.233.89.48

Row	Payload	Status	Anomaly r...	Words	Length	Time	Arrival	Label	Qu
4510	4498	200	32,400	87	297	285826	38319404		
0	0001	400	3	86	285	34621	42421		
1	0003	400	3	86	285	52623	61127		
2	0017	400	3	86	285	70107	78857		
3	0000	400	3	86	285	143384	151042		
4	0002	400	3	86	285	157779	166305		
5	0004	400	3	86	285	211037	219579		
6	0006	400	3	86	285	244736	253293		
7	0008	400	3	86	285	253764	262346		

PrettyRawHex

```
15 {  
  "username": "lab3",  
  "reset_pin": "4498",  
  "new_password": "222"  
}
```

0 highlights

PrettyRawHexRender

```
10 {  
11   "message": "Password has been reset successfully",  
12   "status": "success"  
13 }  
14
```

0 highlights

Reqs: 9999 | Queued: 0 | Duration: 87 | RPS: 115 | Connections: 118 | Retries: 0 | Fails: 0 | Next: null | Completed |

Halt

MerdekaBank

UTAMA

Profil

Transfer Uang

Pinjaman

AKTIVITAS

Transaksi

Kartu Virtual

lab3

Akun Pribadi

Selamat datang kembali, lab3

Wednesday, August 5, 2026

SALDO TERSEDIA

Acct 7745559462

\$1000.0

SALIN

TRANSFER CEPAT

Kirim uang seketika

Kirim Uang +

KARTU VIRTUAL

Kelola kartu Anda

Lihat Kartu +

Kirim Uang

Ajukan Pinjaman

Kartu Virtual

Bayar Tagihan

Profil

Status

Closed

PRICILLA RULY – Cyber Security Portfolio